informe

1. ¿Cuál era la principal superficie de ataque?

Las conexiones de red hacia PostgreSQL.

2. ¿Qué configuración representaba el mayor riesgo?

pg_hba.conf permitiendo all/all desde 0.0.0.0/0.

3. ¿Qué cambio produjo la mayor reducción de exposición?

Restringir orígenes mediante pg_hba.conf, firewall y listen_addresses.

4. ¿Qué diferencia existe entre firewall y pg_hba.conf?

El firewall filtra tráfico de red; pg_hba.conf controla la autenticación dentro de PostgreSQL.

5. ¿Qué diferencia existe entre autenticación y autorización?

Autenticación = identidad. Autorización = permisos.

6. ¿Por qué una cuenta de aplicación no debe ser SUPERUSER?

Si esa cuenta es vulnerada todo el servidor también lo será.

7. ¿Por qué cambiar el puerto de PostgreSQL no constituye hardening suficiente?

Porque no elimina vulnerabilidades ni restringe accesos; solo reduce detección casual.

8. ¿Por qué listen_addresses='*' puede ser innecesario?

Porque expone PostgreSQL en interfaces que no requieren acceso.

9. ¿Qué papel tiene el sistema operativo en la seguridad de PostgreSQL?

Protege archivos, configuraciones, procesos y el directorio de datos.

10. ¿Qué controles deberían revisarse periódicamente?

Roles, permisos, pg_hba.conf, firewall, TLS, extensiones, logs, conexiones activas y actualizaciones de seguridad.